

Security Audit Report

Day 27 — Security & Secret Management | Weeks 1–4 Workflow Review

1. Scope

This audit covered all n8n workflows built during Weeks 1–4, exported as JSON files and stored locally. The goal was to confirm that no credentials, API keys, tokens, or other sensitive values were hard-coded into workflow definitions, scripts, or committed to version control, and to harden at least one public-facing webhook with an authentication check.

2. Method

All exported workflow JSON files were scanned from the command line using PowerShell's `Select-String` (the Windows equivalent of `grep`), searching for common secret-related keywords and patterns:

- Keyword scan: `api key`, `secret`, `password`, `token`, `bearer` (case-insensitive) across all `.json` files
- Pattern scan: OpenAI-style key prefixes (`sk-`), Bearer token values, and URLs containing embedded credentials (`user:password@host`)

3. Findings

Check	Result
Keyword scan (key/secret/password/token/bearer)	0 matches — no hits
Pattern scan (sk-, Bearer tokens, embedded URL credentials)	1 match reviewed — false positive
Credential storage method used in workflows	n8n Credentials system (references only, no raw values in export)

False positive detail: the single pattern match was in `Day26_Workflow.json`, inside a JavaScript Code node. The regex matched a colon that appeared in an unrelated `fetch()` options object (`method: 'GET'`), immediately following a fake test URL used for retry-logic testing. No real domain, credential, or secret value was present.

4. Fix Applied

The **support-ticket** webhook (used in the AI ticket-routing workflow that classifies incoming messages into billing / technical / sales / general and emails the right team) was previously open with no authentication. It was hardened as follows:

- Authentication changed from None to Header Auth on the Webhook node
- New credential created with a non-obvious header name (`x-webhook-secret`)
- Header value set to a long, randomly generated string (not a guessable word or short password)
- Verified: requests without the header are rejected; requests with the correct header succeed

5. Checklist

Item	Status
No hard-coded passwords in nodes	Confirmed clean
No secrets committed to GitHub / version control	Confirmed clean (local export scan)
No secrets stored in docs/screenshots reviewed	Confirmed clean
Credentials stored via n8n Credentials system	Confirmed
At least one webhook secured with auth check	Done — support-ticket webhook
Random, non-guessable secret value used	Done

6. Recommendations Going Forward

- Apply the same Header Auth pattern to any other public webhooks added in future weeks
- If a real secret is ever accidentally committed or exposed, rotate it immediately at the source rather than just deleting it from the file
- Avoid generic header/field names like key or token where possible; prefer descriptive, non-obvious names
- Re-run this scan periodically (e.g. before each week's deliverable) as workflows grow

Audit performed: Day 27 of learning curriculum — Security & Secret Management